אפיון מלא (7 חלקים)

התחייבות שאף אחד לא רואה. שאי אפשר לחזור ממנה. ושמופעלת בבת אחת, או בכלל לא.

חלק 1: נעילת התחייבות

כל חברה נועלת התחייבות במעטפה אטומה: אפשר לראות שהיא קיימת, אי אפשר לראות מה בתוכה, ואי אפשר להחליף את התוכן אחר כך.

איך זה עובד

- החברה בוחרת ערך סודי (מה היא מתחייבת אליו) ומספר אקראי שמסתיר אותו.
- מחשבים מהשניים התחייבות בשיטת Pedersen: C = g^v · h^r, על עקום אליפטי עם g ו-h קבועים ומוסכמים.
- C מתפרסם. הוא לא חושף דבר על הערך (הסתרה), ואי אפשר למצוא ערך אחר שייתן את אותו C (קשירה).
- הערך והמספר האקראי נשארים רק אצל החברה, עד רגע החשיפה.

מה זה מגן מפניו

האיום: חברה משנה את דעתה אחרי שראתה מה האחרות עשו, וטוענת שהתחייבה למשהו אחר.

התשובה: ההתחייבות הנעולה לא מתאימה לשום ערך אחר, והשינוי מתגלה בחשיפה.

הכלים שמאחורי החלק

- **Pedersen Commitment (טכנולוגיה קיימת):** סכימת התחייבות קריפטוגרפית: מעטפה אטומה שאפשר לסגור ולפתוח, ולא להחליף את מה שבתוכה. כל חברה מחשבת C = g^v · h^r ומפרסמת רק אותו. בחשיפה כולם בודקים שהחישוב מחדש נותן את אותו C.
- **ספריות עקומים אליפטיים (libsodium / py_ecc) (טכנולוגיה קיימת):** ספריות שממממשות את החשבון על עקומים אליפטיים, ועברו ביקורות אבטחה רבות. הן מחשבות את הפעולות שמאחורי ההתחייבות, g^v · h^r.
- **PostgreSQL (טכנולוגיה קיימת):** מסד נתונים יחסי בוגר ואמין. הוא שומר חלונות, התחייבויות, חשיפות, יומן ותגי מטרה בשמונה טבלאות.

נתונים

Commitment: commitment_id, company_id (מי הגישה. הזהות גלויה לציבור מההתחלה), commitment_value (g^v · h^r, לא הערך עצמו), submitted_at (מתי הוגשה), purpose_tag (המטרה המאושרת)

קלט ופלט: ערך סודי v, בזיכרון הפרטי של החברה ← התחייבות פומבית שלא חושפת דבר

חלק 2: חשיפה מתואמת

המעטפות נפתחות רק כשהגיע הסף, כולן יחד, ורק אחרי שכל חשיפה נבדקה.

איך זה עובד

- המתאם סופר התחייבויות שהתקבלו.
- ברגע שהגיעו לסף שנקבע מראש (M מתוך N), נשלחת בקשת חשיפה לכל המשתתפים בבת אחת.

- כל חברה חושפת את הערך והמספר האקראי שלה. כל אחד יכול לבדוק שהחישוב נותן את ההתחייבות המקורית.
- רק כשכל החשיפות אומתו מופעלת ההשהיה.

איזו טעות זה מונע

האיום: חברה חושפת ערך נוח אחרי שראתה את האחרות, או מסרבת לחשוף.

התשובה: חשיפה בו-זמנית ואימות פומבי. אי התאמה או סירוב מבטלים את הסבב.

הכלים שמאחורי החלק

- **סף M מתוך N (החלטה שלנו):** כלל שקובע כמה מתוך N המשתתפים צריכים להתחייב כדי שההשהיה תופעל. הוא מוגדר לכל סבב: למשל ארבע מתוך שש מעבדות.
- **Hash Time-Locked Contract (HTLC) (טכנולוגיה קיימת):** חוזה שנעול בתנאי ובשעון: אם התנאי לא מתקיים בזמן, הכול חוזר אוטומטית. לקחנו את הרעיון: אם הסף לא הושג בחלון, ההתחייבויות מתבטלות מעצמן.
- **Pedersen Commitment (טכנולוגיה קיימת):** סכימת התחייבות קריפטוגרפית: מעטפה אטומה שאפשר לסגור ולפתוח, ולא להחליף את מה שבתוכה. כל חברה מחשבת $C = g^v \cdot h^r$ ומפרסמת רק אותו. בחשיפה כולם בודקים שהחישוב מחדש נותן את אותו C.

נתונים

RevealEvent: commitment_id (איזו התחייבות נחשפת), revealed_value (הערך שנחשף), blinding_factor (המספר האקראי), verified (האם החישוב נותן את ההתחייבות)

קלט ופלט: ערך ומספר אקראי מכל משתתף, אחרי הגעה לסף ← אימות מתמטי והפעלת ההשהיה

חלק 3: יומן ציבורי נגד התחייבות כפולה

כולם רואים אותה רשימת התחייבויות בדיוק. חברה לא יכולה להראות לצד אחד דבר אחד ולצד אחר דבר אחר.

איך זה עובד

- כל התחייבות מתווספת ליומן ציבורי בנוי כעץ Merkle: טביעת אצבע אחת לכל הרשימה.
- אחרי כל הוספה, הראש של העץ נחתם ומתפרסם.
- משתתפים משווים ביניהם את הראש שכל אחד קיבל (Gossip).
- אם שני צדדים קיבלו ראשים שונים, יש הוכחה שמישהו פיצל את היומן.

מה זה מגן מפניו

האיום: שרת או חברה מראים לכל צד גרסה אחרת של הרשימה (Equivocation).

התשובה: ההשוואה בין משתתפים חושפת פיצול מיד, כי טביעת האצבע לא תתאים.

הכלים שמאחורי החלק

- **עץ Merkle + ראש חתום (STH) (טכנולוגיה קיימת):** עץ של טביעות אצבע שבו כל שינוי ברשימה משנה את הראש, והראש נחתם. כל התחייבות היא עלה בעץ. אחרי כל הוספה הראש נחתם ומתפרסם.
- **חתימה Ed25519 על ראש העץ (טכנולוגיה קיימת):** שיטת חתימה דיגיטלית מודרנית, מהירה וקטנה. כל ראש עץ חדש נחתם, וכל משתתף יכול לבדוק את החתימה.

- **בדיקת עקביות בין משתתפים (Gossip) (חיבור שבנינו מאפס):** משתתפים עצמאיים משווים ביניהם את הראש שכל אחד ראה, כדי לגלות אם הראו להם גרסאות שונות. כל משתתף שומר את הראש האחרון שקיבל, ומדי פעם שולח אותו לאחרים ומשווה.
- **CONIKS (מאמר מחקר) (טכנולוגיה קיימת):** מערכת מחקרית משנת 2015 ליומן מפתחות שקוף, שמונעת מהשרת להראות לצדדים שונים תשובות שונות. הרעיון של יומן ציבורי עם בדיקות עקביות בין משתתפים הוא הבסיס לעיצוב היומן שלנו.
- **S3 Object Lock (גיבוי שלא נמחק) (טכנולוגיה קיימת):** אחסון שאי אפשר למחוק או לשכתב בו קבצים לתקופה קבועה, אפילו למי שיש לו גישה. הראשים החתומים של היומן משוכפלים אליו, כך שגם מי שפורץ למסד הראשי לא יכול לשכתב היסטוריה שפורסמה.

נתונים

LedgerEntry: leaf_hash (טביעת אצבע של ההתחייבות), merkle_root_after (ראש העץ אחרי ההוספה), signed_tree_head (הראש החתום), timestamp (מתי נוספה)

קלט ופלט: התחייבות חדשה להוספה ← ראש עץ מעודכן וחתום, שכל צד יכול לבדוק

חלק 4: חלון זמן וחזרה אוטומטית

מי שנעל ונעלם לא תוקע את כולם. כשהזמן נגמר, הכול מתבטל וחוזר.

איך זה עובד

- לכל סבב יש חלון זמן, למשל 72 שעות, ובו צריך להגיע לסף.
- אם הסף הושג, עוברים לחשיפה.
- אם הזמן נגמר לפני כן, כל ההתחייבויות מתבטלות אוטומטית, בלי הסכמה של אף אחד.
- כל חברה יכולה להגיש מחדש בסבב חדש.

איזו טעות זה מונע

האיום: חברה נועלת ונעלמת, והמערכת נתקעת במצב המתנה לנצח.

התשובה: פקיעת חלון וחזרה אוטומטית, בהשראת מסלול ההחזר של HTLC.

הכלים שמאחורי החלק

- **חלון זמן עם מצבים (החלטה שלנו):** לכל סבב יש שעון ומצב: ממתין, הסף הושג, הופעל או פג. סבב נפתח עם זמן סיום, והמצב משתנה רק לפי כללים קבועים, כך שאי אפשר להיתקע.
- **Hash Time-Locked Contract (HTLC) (טכנולוגיה קיימת):** חוזה שנעול בתנאי ובשעון: אם התנאי לא מתקיים בזמן, הכול חוזר אוטומטית. לקחנו את הרעיון: אם הסף לא הושג בחלון, ההתחייבויות מתבטלות מעצמן.
- **PostgreSQL (טכנולוגיה קיימת):** מסד נתונים יחסי בוגר ואמין. הוא שומר חלונות, התחייבויות, חשיפות, יומן ותגי מטרה בשמונה טבלאות.

נתונים

CommitmentWindow: window_id (מזהה הסבב), opened_at (מתי נפתח), expires_at (מתי נגמר), required_threshold (הסף הנדרש), status (OPEN, FULFILLED או EXPIRED)

קלט ופלט: סף נדרש וזמן סיום ← סבב שהושלם, או ביטול וחזרה

חלק 5: הגנה מפני שימוש לרעה

המנגנון מוגבל טכנית למטרה אחת: השהיית סיכון בטיחותי. לא תיאום מחירים, ולא שום דבר אחר.

איך זה עובד

- לכל התחייבות חייב להיות תג מטרה מתוך רשימה סגורה ומאושרת, לא טקסט חופשי.
- גורם ניטרלי (לא צד מסחרי) חותם על כל תג חדש שנכנס לרשימה.
- זהות המשתתפים גלויה לציבור מהרגע הראשון. רק תוכן ההתחייבות נשאר נעול.
- ההיצמדות הטכנית למטרה המאושרת היא מה שיאפשר בעתיד להישען על Safe Harbor משפטי.

מה זה מגן מפניו

האיום: חברות משתמשות במנגנון כדי לתאם מחירים או חלוקת שוק, ולא להשהיית סיכון.

התשובה: רק מטרה מאושרת נכנסת והמשתתפים גלויים, כך שאי אפשר להקים מועדון סודי.

הכלים שמאחורי החלק

- **רשימת מטרות סגורה (החלטה שלנו):** רשימה קבועה של סיבות מותרות להשהיה, בלי טקסט חופשי. כל התחייבות נושאת תג מהרשימה, והמערכת דוחה כל תג אחר.
- **מפתח גורם ניטרלי (Regulatory Observer Key) (חיבור שבנינו מאפס):** מפתח חתימה שמוחזק על ידי גורם שאינו צד מסחרי, למשל רגולטור משקיף. כל תג חדש חייב חתימה שלו לפני שהוא נכנס לרשימה.
- **Safe Harbor (דפוס משפטי) (החלטה שלנו):** עיקרון משפטי מוכר בדיני הגבלים עסקיים: פעילות צרה ומוגדרת היטב נהנית מחסינות אם היא עומדת בתנאים קבועים מראש. התכנון הטכני נצמד למטרה המאושרת, כדי שבעתיד אפשר יהיה לטעון להגנה כזו.

נתונים

ApprovedPurposeTag: tag_id (מזהה התג), tag_name (למשל capability-pause:autonomous-replication), description (תנאי השימוש המדויקים), approved_by (מי חתם ומתי)

קלט ופלט: תג מטרה מוצע ← אושר וחתום, או נדחה

חלק 6: הרחבה ל-N צדדים

לא רק שתי חברות. כל מספר של חברות, עם סף גמיש, בלי צד אחד שסומכים עליו.

איך זה עובד

- קובעים סף M מתוך N, למשל ארבע מתוך שש מעבדות.
- כל חברה מזינה את הקלט שלה לחישוב משותף (MPC) בלי לחשוף אותו.
- החישוב עונה על שאלה אחת: האם הגענו לסף?
- המערכת ממשיכה לעבוד נכון גם אם פחות ממחצית המשתתפים נופלים או משקרים.

איזו טעות זה מונע

האיום: צד שלישי יחיד שכולם סומכים עליו, והופך לנקודת כשל.

התשובה: חישוב משותף בלי צד מהימן, שעמיד בפני משתתפים משבשים.

הכלים שמאחורי החלק

- **MP-SPDZ (טכנולוגיה קיימת):** ספרייה אקדמית בקוד פתוח לחישוב משותף מאובטח (MPC) בין כמה צדדים. היא מריצה את החישוב "האם הגענו לסף?" בלי שאף חברה תחשוף את הקלט שלה.
- **סף M מתוך N (החלטה שלנו):** כלל שקובע כמה מתוך N המשתתפים צריכים להתחייב כדי שההשהיה תופעל. הוא מוגדר לכל סבב: למשל ארבע מתוך שש מעבדות.

נתונים

MpcSession: session_id (מזהה הסבב), participants (מי משתתף), threshold_m (כמה צריך), result (הושג או לא)

קלט ופלט: קלט פרטי מכל חברה ← תשובה אחת: הסף הושג או לא

חלק 7: הוכחת השתתפות בלי חשיפה

כל מי שבחוץ יכול לוודא שלפחות K חברות התחייבו, בלי לדעת אילו ובלי לדעת על מה.

איך זה עובד

- בונים מעגל חישובי שבודק: "קיימים לפחות K ערכים תקפים ביומן".
- מפיקים הוכחה קצרה (zk-SNARK) שמאשרת את הטענה בלי לחשוף את הערכים.
- ההוכחה מתפרסמת יחד עם הקלטים הציבוריים: הסף ושורש העץ.
- כל אחד יכול לאמת אותה בשניות, בלי אינטראקציה עם המוכיח.

איזו טעות זה מונע

האיום: פרסום מלא של ההתחייבויות פוגע במי שהתחיל, ושתיקה מלאה לא נותנת אמון לציבור.

התשובה: שקיפות חלקית: הציבור יודע שהסף הושג, והמשתתפים נשארים מוגנים.

הכלים שמאחורי החלק

- **circom + snarkjs (טכנולוגיה קיימת):** ערכת כלים לכתיבת מעגלים חישוביים, להפקת הוכחות zk-SNARK ולאימותן. היא מפיקה הוכחה שיש לפחות K התחייבויות תקפות ביומן, בלי לחשוף אילו.
- **עץ Merkle + ראש חתום (STH) (טכנולוגיה קיימת):** עץ של טביעות אצבע שבו כל שינוי ברשימה משנה את הראש, והראש נחתם. כל התחייבות היא עלה בעץ. אחרי כל הוספה הראש נחתם ומתפרסם.

נתונים

ZkParticipationProof: proof_id (מזהה ההוכחה), window_id (איזה סבב), proof_blob (פלט ה-SNARK), public_inputs (הקלטים הציבוריים), verified (האם אומתה)

קלט ופלט: יומן ההתחייבויות וסף K ← הוכחה שכל אחד יכול לאמת

ההחלטות

גיבוב פשוט או Pedersen?

בחרנו Pedersen. המספר האקראי מסתיר גם ערך שיש לו מעט אפשרויות, והמבנה האלגברי מתאים להוכחות ללא ידיעה בהמשך.

המחיר: חישוב על עקום אליפטי, ותלות בספרייה קריפטוגרפית מבוקרת.

מתאם שסומכים עליו או מתאם שכולם מבקרים?

בחרנו מתאם שכולם מבקרים. המתאם סופר ומפעיל, אבל כל תוצאה ניתנת לאימות עצמאי מהיומן הציבורי. אין צד שצריך להאמין לו.

המחיר: כל משתתף חייב להריץ בדיקות בעצמו, ולא רק לקבל תשובה.

טקסט חופשי או רשימת מטרות סגורה?

בחרנו רשימה סגורה. רק תגים שאושרו מראש נכנסים, וגורם ניטרלי חותם על כל אחד. כך המנגנון מוגבל למה שנועד לו.

המחיר: פחות גמישות, ותהליך אישור לכל מטרה חדשה.

בלי הגבלת זמן או חלון של 72 שעות?

בחרנו חלון זמן קבוע. כשהחלון נגמר בלי שהסף הושג, הכול מתבטל וחוזר. אף חברה לא נשארת כבולה להבטחה שאיש לא ענה לה.

המחיר: סבב שנכשל חייב להתחיל מחדש.

לחשוף בזה אחר זה או כולם יחד?

בחרנו חשיפה בו-זמנית. אחרי שהסף הושג, כולן חושפות באותו רגע. אף אחת לא רואה את הקלפים של האחרות לפני שהיא מראה את שלה.

המחיר: צריך לתאם רגע חשיפה אחד לכולן.

רשימה גלויה או הוכחה ללא ידיעה?

בחרנו הוכחה ללא ידיעה. מוכיחים לציבור שהסף הושג בלי להראות מי התחייב. כך אמון הציבור לא בא על חשבון מי שהעז להתחיל.

המחיר: מעגל הוכחה מורכב שצריך לבנות ולבדוק.

מה השתנה מהגרסה הראשונה

קודם	עכשיו
שני צמתים מדומים בלבד	כל מספר חברות, סף M מתוך N
התחייבות Pedersen פשוטה	יומן ציבורי חתום שמונע שליחת התחייבויות שונות לצדדים שונים
לא טיפלנו בחברה שנעלמת	חלון זמן ונתיב חזרה אוטומטי
הנחנו שמישהו מפעיל את המערכת	כל אחד יכול לאמת, בלי רשות מהימנה אחת
לא טיפלנו בשימוש לרעה	מטרה מאושרת מרשימה סגורה, וזהות המשתתפים גלויה